

example.com.au

Checked 2026-10-07 09:53 UTC

67

out of 100

Fair. Website hardening is the weakest area. Fixing the top items below would lift the score from 67 to about 93.

1 to fix, 3 to improve, 1 not detected, 4 good

Areas

Email protection

Stops others sending mail as you.



SPF (Good), DMARC (Improve), DKIM (Not Detected)

Encryption and HTTPS

Keeps visits private and trusted.



TLS certificate (Good), TLS versions (Good), HTTPS redirect and HSTS (Improve)

Website hardening

Browser protections and certificate controls.



Security headers (Fix Now), Cookie flags (Good), CAA (Improve)

Fix these first

Ordered by how many score points each fix is worth. Effort is a typical estimate.

#	FIX	WHAT TO DO	POINTS	EFFORT
1	Security headers	Add the missing headers	+9.5	15 min
2	DMARC	Add reporting, then enforce	+9.5	10 min
3	HTTPS redirect and HSTS	Add an HSTS header	+7.1	5 min
4	DKIM	Turn on DKIM signing	+4.8	15 min

All findings

FIX NOW Security headers

Missing: Content-Security-Policy, Referrer-Policy, Permissions-Policy.

Worth about +9.5 points if fixed.

EVIDENCE

X-Content-Type-Options: {"verdict": "ok"}

HOW TO FIX - ABOUT 15 MIN

Several security headers are missing. Add them at your web host, CDN or web server.

Steps

1. X-Content-Type-Options: nosniff
2. X-Frame-Options: DENY (or SAMEORIGIN if you embed your own pages), or a CSP frame-ancestors rule.
3. Referrer-Policy: strict-origin-when-cross-origin
4. Permissions-Policy: camera=(), microphone=(), geolocation=()
5. Content-Security-Policy: start in report-only mode, then enforce once nothing breaks.
6. Cloudflare, Netlify, Vercel and most hosts let you add response headers in their settings or a config file.

Provider screens change. If a step does not match, check your provider's help pages.

IMPROVE DMARC (what receivers do with forged mail)

DMARC is in monitoring mode (p=none). It reports problems but does not stop forged mail. No reporting address (rua) is set, so you will not see who sends as your domain.

Worth about +9.5 points if fixed.

EVIDENCE

```
record: v=DMARC1; p=none
policy: none
reporting address: none
```

HOW TO FIX - ABOUT 10 MIN

Move from monitoring to enforcement once reports show your genuine mail passes.

Steps

1. Review the reports sent to your rua address for a few weeks.
2. Change p=none to p=quarantine, then later to p=reject.
3. If pct is below 100, raise it to 100 when you are confident.
4. If there is no rua= address, add one so you can see who sends as your domain.

Provider screens change. If a step does not match, check your provider's help pages.

IMPROVE HTTPS redirect and HSTS

No usable HSTS header, so browsers are not told to always use HTTPS.

Worth about +7.1 points if fixed.

EVIDENCE

```
http: {"status": 301, "location": "https://example.com/"}
hsts: none
```

HOW TO FIX - ABOUT 5 MIN

Add or lengthen the HSTS header so browsers always use HTTPS.

Steps

1. Add the response header: Strict-Transport-Security: max-age=31536000; includeSubDomains
2. Only add includeSubDomains if every subdomain works over HTTPS.
3. Start with a short max-age if you are unsure, then raise it to at least 180 days (15552000).

Provider screens change. If a step does not match, check your provider's help pages.

IMPROVE CAA (who may issue certificates)

No CAA record was found. A CAA record is optional hardening.

Worth about +2.4 points if fixed.

HOW TO FIX - ABOUT 5 MIN

Optional: publish a CAA record naming the certificate authority you use.

Steps

1. Find out which authority issues your certificate (look at the certificate details in your browser).
2. In your DNS manager add a CAA record at the root with flag 0, tag issue and the authority's domain, for example letsencrypt.org or digicert.com.
3. If you use a host that issues certificates for you (such as a CDN), add that provider's authority too, or issuing will fail.

cPanel

1. In cPanel open Zone Editor and add a CAA record for the root domain.
2. AutoSSL uses Sectigo or Let's Encrypt depending on setup; check which before restricting.

Provider screens change. If a step does not match, check your provider's help pages.

NOT DETECTED DKIM (signed email)

No DKIM key was found under the common selector names we tried. This does not prove DKIM is off: your provider may use a different selector name.

Worth about +4.8 points if fixed.

EVIDENCE

selectors checked: ["default", "google", "selector1", "selector2"]

HOW TO FIX - ABOUT 15 MIN

Turn on DKIM signing at your email provider and publish the key it gives you. We only test common selector names, so if DKIM is already on under a custom name, this result may be a false alarm.

Microsoft 365

1. In the Microsoft Defender portal, find the DKIM setting under email authentication settings and select your domain.
2. Microsoft shows two CNAME records (selector1 and selector2 under _domainkey). Publish both in your DNS manager.
3. Return to the DKIM page and switch signing on for the domain.

Google Workspace

1. In the Google Admin console, open Gmail settings, then Authenticate email.
2. Select your domain and generate a new key, choosing a 2048-bit key.
3. Publish the TXT record it shows in your DNS manager, then click Start authentication.

cPanel

1. In cPanel open Email Deliverability and click Manage next to your domain.
2. If DKIM shows a problem, use the Repair or Install button. cPanel creates and publishes the key for you when it hosts your DNS.

Provider screens change. If a step does not match, check your provider's help pages.

GOOD SPF (who may send email as your domain)

An SPF record is published and valid. '~all' marks other mail as suspicious; '-all' is stricter.

EVIDENCE

record: v=spf1 include:spf.protection.outlook.com ~all
dns lookups: 3

GOOD TLS certificate

The certificate is valid and trusted (61 days left).

EVIDENCE

issuer: Let's Encrypt
valid until: 2026-12-08
days left: 61

GOOD TLS versions

Only modern TLS versions are accepted (TLS 1.2, TLS 1.3).

EVIDENCE

supported: ["TLS 1.2", "TLS 1.3"]

GOOD Cookie flags

The home page does not set any cookies.

How the score works

Each check has a weight. A pass earns the full weight, a warning half, and a fail none. "Not detected" counts as a warning, and a check that could not run is left out. Weights are a judgement call. This report comes from passive checks (DNS records, the certificate and the home page) and is a snapshot, not a full security assessment.

Weights: DMARC 20, HTTPS redirect and HSTS 15, SPF 15, TLS certificate 15, Security headers 10, DKIM 10, TLS versions 10, CAA 5, Cookie flags 5.